

SCHOOL OF COMPUTER SCIENCE AND ENGINEERING

B.Tech, Winter Semester , 2025-26

Cryptography and Network Security Case Study – II

**Vamsi Krishna
23BCI0024**

PQCFIA

Post-Quantum Cryptographic Firmware Integrity Attestation

A Context-Specific Security Mechanism for IoT Firmware Integrity

1. Problem Description

1.1 Problem Statement

IoT medical and industrial devices including insulin pumps, pacemaker controllers, PLCs, and SCADA sensors receive periodic firmware updates over-the-air (OTA) or via physical interfaces. These firmware images are the root of trust for device behavior. An adversary who successfully injects tampered firmware gains persistent, privileged control over both the device and, by extension, the physical process it governs.

Critically, as quantum computing advances, classical signature schemes (RSA-2048, ECDSA P-256) used to authenticate firmware packages become vulnerable to Shor's algorithm. A "Harvest Now, Decrypt Later" (HNDL) attacker can intercept and store signed firmware today and forge valid signatures retroactively once quantum hardware matures a timeline now estimated at 5-10 years.

1.2 Real-World Context and Motivation

- In 2019, FDA issued an advisory for Medtronic insulin pump vulnerabilities (CVE-2019-10964) enabling unauthorized firmware changes via RF.
- In 2021, ForeScout and Medigate researchers reported "NAME:WRECK" nine TCP/IP stack vulnerabilities in medical IoT firmware affecting 100M+ devices.
- The U.S. NIST completed its Post-Quantum Cryptography standardization in 2024 (FIPS 203, 204, 205), explicitly recommending transition timelines for critical infrastructure.
- Supply chain attacks (SolarWinds 2020, XZ Utils 2024) demonstrate that even signed builds can be compromised at the vendor signing stage.

The problem is therefore: existing IoT firmware integrity mechanisms lack quantum resistance, offer no runtime behavioral verification, and fail gracefully under key compromise creating an unacceptable risk profile for safety-critical deployments.

2. Existing Solutions with Proof & Identified Gaps

2.1 Solution 1: ARM TrustZone-Based Secure Boot

Working: ARM's Platform Security Architecture (PSA) defines a hardware-enforced chain of trust. A ROM-resident bootloader verifies the next-stage bootloader using a public key burned into OTP fuses, which in turn verifies the application firmware image using RSA-2048 or ECDSA signatures before execution. TrustZone-M creates an isolated Secure World for key storage and cryptographic operations, inaccessible to the Normal World application.

Documentary Proof: ARM Ltd., "Platform Security Architecture (PSA) Level 1 Threat Model and Security Analysis," ARM IHI0086A (2019). Also: U. Pricope, "Security Analysis of Embedded Systems Bootloaders," ACM DTRAP, Vol. 2(1), 2021, Article 2.

Identified Technical Limitations:

- Classical cryptography only: RSA/ECC signing is broken by Shor's algorithm on a cryptographically relevant quantum computer (CRQC). No PQC fallback is defined in the PSA v1.x specification.
- Boot-time verification only: TrustZone does not monitor firmware behavior after successful boot. A malicious payload that passes signature verification (e.g., via key compromise) executes undetected.
- Single-key compromise is catastrophic: If the vendor's private signing key is stolen or leaked (cf. XZ Utils), all devices trusting that key are permanently compromised without a hardware re-flash.

- No OTA transport security standardization: PSA defines firmware verification but not the channel over which firmware is delivered, leaving the update path vulnerable.

2.2 Solution 2: AWS IoT Device Defender

Working: AWS IoT Device Defender is a cloud-managed security service that continuously audits IoT device configurations (checking for open ports, default credentials, certificate misuse) and detects behavioral anomalies by comparing device metrics MQTT message rates, TCP connection counts, data transfer volumes against cloud-defined ML baselines. It integrates with AWS IoT Core and triggers Lambda-based remediation workflows on detection.

Documentary Proof: Amazon Web Services, "AWS IoT Device Defender Developer Guide," AWS Documentation (2024). Also: Y. Meidan et al., "N-BaIoT: Network-Based Detection of IoT Botnet Attacks Using Deep Autoencoders," IEEE Pervasive Computing, Vol. 17(3), pp. 12–22, 2018.

Identified Technical Limitations:

- Cloud connectivity dependency: All behavioral telemetry must be transmitted to AWS infrastructure. Devices operating in air-gapped, offline, or low-bandwidth environments (e.g., industrial plant floors, undersea sensors) cannot be monitored.
- Latency of threat response: Anomaly detection pipelines involve cloud ingestion, ML inference, and callback latency measured in minutes. For safety-critical devices, this is unacceptably slow.
- Firmware integrity is not verified on-device: Device Defender monitors network behavior, not the cryptographic integrity of the running firmware image. A tampered firmware that mimics normal network behavior evades detection entirely.
- Vendor lock-in and recurring cost: Device Defender pricing at INR0.0011 per device/month plus per-audit costs makes it uneconomical for large-scale deployments (10M+ devices) and introduces dependency on AWS infrastructure availability.

2.3 Comparative Gap Analysis

Criterion	Secure Boot (ARM TrustZone)	AWS IoT Device Defender
Quantum Resistance	None (RSA/ECC signing)	None (RSA/ECC TLS)
Offline Operation	Yes	No (cloud-dependent)
Runtime Monitoring	No (boot-time only)	Yes (cloud-side only)
Key Compromise Recovery	Requires hardware re-flash	Possible via rotation
Scalability	Per-device hardware cost	SaaS scalable but costly
Real-time Threat Response	None	Minutes-level latency

3. Proposed System Architecture

3.1 Overview: PQCFIA

PQCFIA (Post-Quantum Cryptographic Firmware Integrity Attestation) is a layered security mechanism that addresses the identified gaps through four complementary components: (1) a PQC-signed firmware packaging pipeline at the vendor, (2) a Zero-Trust OTA gateway enforcing post-quantum mutual TLS, (3) an on-device composite verifier combining PQC signature verification with SHA-3 hash checking, and (4) a Runtime Behavioral Fingerprinter (RBF) for post-boot integrity monitoring all integrated with an immutable incident log.

3.2 Block Diagram

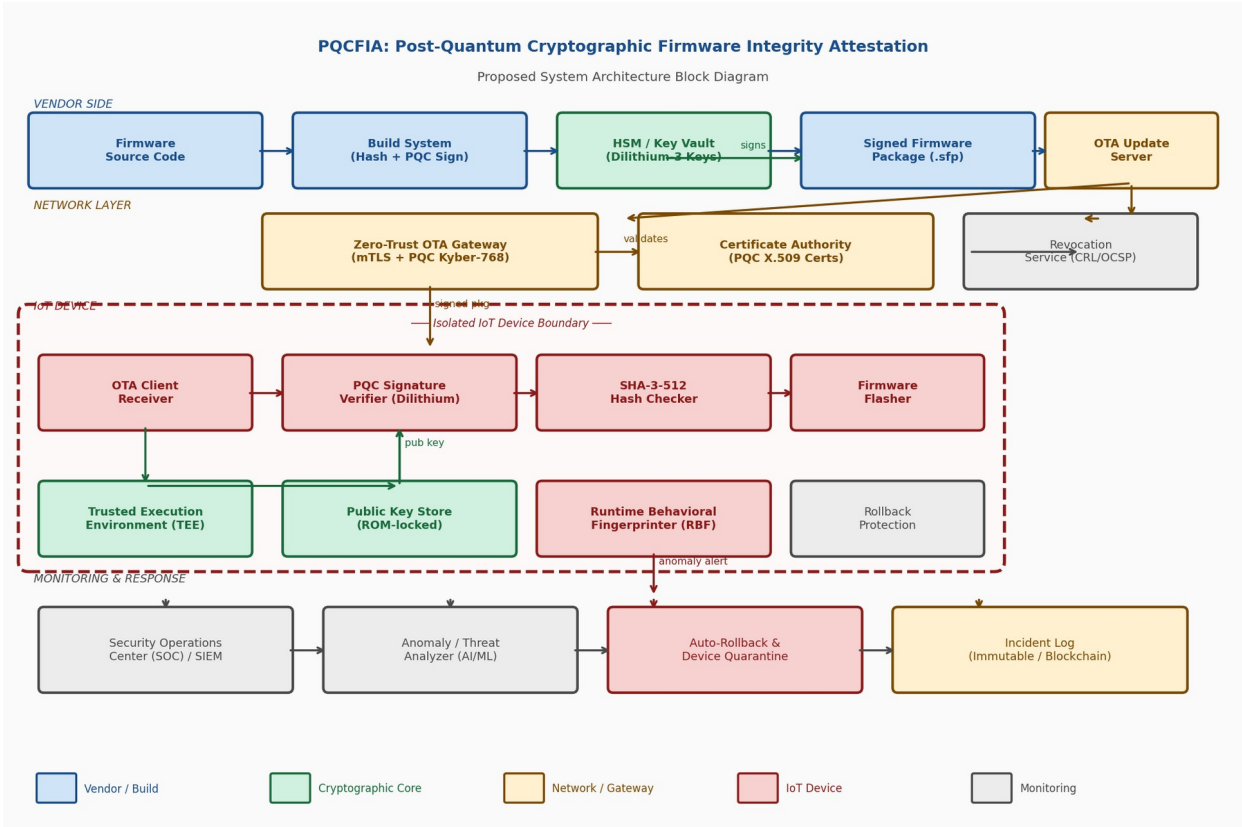


Figure 1: PQCFIA System Architecture Block Diagram

3.3 Component Descriptions

Layer 1 Vendor Signing Pipeline: Firmware is compiled, hashed with SHA-3-512, and signed using CRYSTALS-Dilithium-3 (FIPS 204). The signing private key is stored in a FIPS 140-3 Level 3 HSM. The resulting Signed Firmware Package (.sfp) bundles the firmware binary, its hash, Dilithium signature, version number, and device class identifier.

Layer 2 Zero-Trust OTA Gateway: The OTA server and IoT device perform mutual authentication using PQC X.509 certificates (Kyber-768 KEM + Dilithium-3 for TLS 1.3 hybrid mode). Devices without valid certificates or flagged by the CRL/OCSP revocation service are denied updates. The gateway enforces rate-limiting and geographic anomaly detection.

Layer 3 On-Device Composite Verifier: Upon receiving the .sfp package, the device's TEE retrieves the ROM-locked Dilithium public key and verifies the signature. On success, SHA-3-512 of the received binary is compared against the embedded hash. Only a double-pass firmware proceeds to the flasher. The rollback protection module checks the monotonic version counter stored in OTP registers to prevent downgrade attacks.

Layer 4 Runtime Behavioral Fingerprinter (RBF): A lightweight interrupt-driven module profiles the running firmware's system call patterns, interrupt frequency distributions, and memory access sequences during the first 60 seconds post-boot ("golden window") to establish a behavioral baseline. Subsequent runtime deviations beyond 2-sigma trigger escalating alerts: (a) local isolation, (b) SOC notification, (c) forced rollback to the last verified version.

4. Component Selection and Justification

Component	Technology	Standard/Spec	Justification
-----------	------------	---------------	---------------

PQC Signature	CRYSTALS-Dilithium-3	NIST FIPS 204 (2024)	NIST-standardized PQC; 2.5 KB sig; ECC-equivalent security at 128-bit PQ level
Key Encapsulation	CRYSTALS-Kyber-768	NIST FIPS 203 (2024)	Hybrid TLS handshake; resistant to Harvest-Now-Decrypt-Later attacks
Hash Function	SHA-3-512	FIPS 202	Collision-resistant; Keccak sponge construction; hardware-accelerated on Cortex-M
TEE	ARM TrustZone-M	ARMv8-M	Secure enclave for key storage; cost-effective vs. discrete HSM
Runtime Monitor	Custom RBF Module	Proposed	Lightweight syscall/interrupt profiling; ~4 KB RAM footprint
OTA Protocol	CoAP over DTLS 1.3	RFC 7252 + RFC 9147	Low-overhead for constrained devices; supports fragmentation
Incident Log	IOTA Tangle (optional)	DAG Ledger	Feeless immutable logging suitable for IoT event volumes

The Dilithium-3 and Kyber-768 algorithms were selected as they are NIST-standardized (FIPS 203/204, August 2024) and offer the best balance of signature/key size, verification speed, and security margin for constrained embedded targets. Benchmarks by the Open Quantum Safe (OQS) project show Dilithium-3 verification takes ~310 μ s on a Cortex-M4 at 120 MHz acceptable for firmware update contexts. The RBF module is designed to operate within 4 KB RAM and requires no cloud infrastructure, directly addressing the AWS Device Defender offline limitation.

5. Constraints, Cost, and Limitations

5.1 Cost Estimate

- Hardware (TEE-capable MCU, e.g., STM32L5 or nRF9160): INR 300- 800 per unit (vs. INR100 – 200 for non-TEE MCUs) cost premium of ~INR 200 600 per device.
- HSM for vendor signing infrastructure: INR5,000–INR20,000 one-time (Thales Luna HSM or AWS CloudHSM subscription at ~INR 1,4000/month).
- PQC Library integration (liboqs / PQCclean): Open-source, zero licensing cost; ~80 KB Flash footprint.
- RBF module development and validation: Estimated 3–6 engineer-months for initial implementation, testing, and certification.

5.2 Deployment Challenges

- Legacy device migration: Existing deployed devices without TrustZone-M or sufficient Flash cannot adopt PQCFIA without hardware replacement. A phased rollout strategy is necessary.
- PQC algorithm maturity: While NIST has standardized Dilithium and Kyber, hardware acceleration for these algorithms is not yet widely available in commodity MCUs as of 2025, leading to a 10–20 $\times$ performance overhead vs. ECC in some benchmarks.
- RBF baseline drift: Devices with legitimate firmware updates or configuration changes may trigger false positives if the behavioral baseline is not re-established post-update. An automated re-baselining protocol is required.
- Key management at scale: Maintaining per-device Dilithium certificate chains for 10M+ devices requires robust PKI infrastructure and Certificate Lifecycle Management (CLM) tooling.

5.3 Scalability

The zero-trust OTA gateway is horizontally scalable using a containerized microservice architecture (Kubernetes). The on-device components are entirely local and require no cloud infrastructure, enabling true edge-scale deployment. The immutable incident log, if using IOTA Tangle, is feeless and scales with the number of participating nodes. The primary scalability bottleneck is the HSM throughput for signing operations; this is mitigated by distributing signing across a cluster of HSMs or using threshold signing schemes.

5.4 Limitations

- Physical hardware attacks (fault injection, side-channel) are outside the threat model of PQCFIA; a separate hardware security evaluation is recommended for Tier-1 medical devices.
- The RBF module cannot detect semantically equivalent malicious behavior that mimics legitimate firmware patterns (mimicry attacks), though the coupling with signature verification significantly raises the bar.
- Complete quantum resistance requires hybrid classical+PQC schemes during the transition period, adding ~30% overhead to TLS handshake sizes.

6. Conclusion

This paper identified the emerging threat of quantum-capable adversaries targeting IoT firmware integrity as a critical, under-addressed security problem. Two existing solutions ARM TrustZone Secure Boot and AWS IoT Device Defender were analyzed, revealing complementary but individually insufficient protections: Secure Boot lacks quantum resistance and runtime monitoring; Device Defender lacks on-device verification and offline operation.

PQCFIA addresses these gaps through a four-layer architecture integrating NIST-standardized post-quantum cryptography (Dilithium-3, Kyber-768), a Zero-Trust OTA gateway with PQC mutual TLS, a hardware-backed composite firmware verifier, and a lightweight Runtime Behavioral Fingerprinter. The proposed mechanism is implementable using commercially available components (STM32L5, liboqs, ARM TrustZone-M) at a modest INR2–6 per-device cost premium, without cloud infrastructure dependency.

7. References

1. [1] ARM Ltd., "Platform Security Architecture (PSA) Level 1 Threat Model and Security Analysis," ARM IHI0086A, 2019. [Online]. Available: <https://developer.arm.com/documentation/ih0086/a>
2. [2] U. Pricope, "Security Analysis of Embedded Systems' Bootloaders," ACM Digital Threats: Research and Practice, Vol. 2, No. 1, Article 2, Jan. 2021. DOI: 10.1145/3426966
3. [3] Amazon Web Services, "AWS IoT Device Defender Developer Guide," AWS Documentation, 2024. [Online]. Available: <https://docs.aws.amazon.com/iot/latest/developerguide/device-defender.html>
4. [4] Y. Meidan et al., "N-Balot: Network-Based Detection of IoT Botnet Attacks Using Deep Autoencoders," IEEE Pervasive Computing, Vol. 17, No. 3, pp. 12-22, 2018. DOI: 10.1109/MPRV.2018.03367731
5. [5] NIST, "Module-Lattice-Based Digital Signature Standard (FIPS 204)," National Institute of Standards and Technology, August 2024. DOI: 10.6028/NIST.FIPS.204
6. [6] NIST, "Module-Lattice-Based Key-Encapsulation Mechanism Standard (FIPS 203)," National Institute of Standards and Technology, August 2024. DOI: 10.6028/NIST.FIPS.203
7. [7] U.S. Food and Drug Administration (FDA), "Cybersecurity Vulnerabilities Identified in Medtronic Paradigm Family of Insulin Pumps," Safety Communication, June 2019. [Online]. Available: <https://www.fda.gov/medical-devices/safety-communications/cybersecurity-vulnerabilities-identified-medtronic-paradigm-family-insulin-pumps>
8. [8] ForeScout and Medigate, "NAME:WRECK: Breaking and Fixing DNS Implementations in Popular TCP/IP Stacks," Technical Report, April 2021. [Online]. Available: <https://www.forescout.com/research-labs/namewreck/>
9. [9] Open Quantum Safe Project, "liboqs Benchmarking Results Cortex-M4," OQS Performance Benchmarks, 2024. [Online]. Available: <https://openquantumsafe.org/benchmarking/>
10. [10] D. J. Bernstein and T. Lange, "Post-Quantum Cryptography Dealing with the Fallout of Physics Success," IACR Cryptology ePrint Archive, Report 2017/314, 2017.